



PCL – IT Security Assessment Checklist

Aligned to NIST Cybersecurity Framework

1 IDENTIFY (ID) – Asset & Risk Understanding

Software & Vendor Identification

- ☐ Software name and version
- ☐ Vendor legal name and country of incorporation
- ☐ Deployment model: ☐ On-prem ☐ Cloud ☐ SaaS ☐ Hybrid
- ☐ Business owner identified
- ☐ IT owner assigned

Data & Risk Classification

- ☐ Type of PCL data involved
 - ☐ Public ☐ Internal ☐ Confidential ☐ Restricted
- ☐ Personal data (PII) involved? ☐ Yes ☐ No
- ☐ Financial / operational / strategic data involved? ☐ Yes ☐ No
- ☐ Data residency/location identified

Vendor Risk

- ☐ Vendor security certifications reviewed (ISO 27001 / SOC 2 / equivalent)
- ☐ Vendor security policy available and reviewed
- ☐ Known regulatory or legal risks assessed

2 PROTECT (PR) – Security Controls

Access Control

- ☐ Role-based access control (RBAC) supported
- ☐ Multi-Factor Authentication (MFA) enforced
- ☐ Integration with corporate identity (Azure AD / SSO)
- ☐ Privileged access controls available



Data Protection

- ☐ Data encrypted at rest
- ☐ Data encrypted in transit
- ☐ Customer-managed encryption keys supported (if applicable)
- ☐ Secure data deletion on termination

Secure Configuration

- ☐ Default credentials can be disabled
- ☐ Secure configuration baseline available
- ☐ Supports security hardening

3 DETECT (DE) – Monitoring & Visibility

- ☐ Audit logs available
- ☐ User activity logging enabled
- ☐ Admin actions logged
- ☐ Log retention meets PCL requirements
- ☐ Logs exportable for investigation

4 RESPOND (RS) – Incident Handling

Incident Management

- ☐ Vendor has documented incident response process
- ☐ Breach notification timelines defined
- ☐ Customer notification guaranteed contractually
- ☐ Vendor support escalation path defined

Legal & Contractual

- ☐ Breach responsibility clearly defined
- ☐ Data ownership explicitly remains with PCL
- ☐ Right to audit clause included (where applicable)



5 RECOVER (RC) – Resilience & Exit

- ☐ Backup and recovery mechanism available
- ☐ Recovery Time Objective (RTO) acceptable
- ☐ Recovery Point Objective (RPO) acceptable
- ☐ Business continuity plan documented

Exit & Lock-in

- ☐ Data export available in standard format
- ☐ Secure data deletion guaranteed on exit
- ☐ Vendor lock-in risks assessed

6 SUPPLY CHAIN & AI-SPECIFIC CONTROLS (NIST-Aligned)

Supply Chain Security

- ☐ Third-party dependencies disclosed
- ☐ Sub-processors identified
- ☐ Software update mechanism secured

AI / Cloud / SaaS (If Applicable)

- ☐ AI model does NOT train on PCL data
- ☐ Data anonymization supported
- ☐ Human oversight available
- ☐ Explainability / auditability of outputs
- ☐ No shadow AI usage permitted

7 COMPLIANCE & FINAL DECISION

- ☐ License model compliant and owned by PCL
- ☐ Regulatory compliance verified (local cyber laws, data protection)
- ☐ IT security approval granted ☐ Yes ☐ No
- ☐ Conditions / mitigations documented



Final Recommendation

- ☐ Approved
- ☐ Approved with conditions
- ☐ Rejected

Reviewed by: _____

Date: _____

IT Security Sign-off: _____

Remarks:
